

Политика информационной безопасности ООО «НордСофт»

Код документа: NS-SEC-003

Версия: 4.2

Действует с: 1 апреля 2026 года

Владелец: служба информационной безопасности

Статус: внутренний документ

Учебный документ: компания, адреса и контакты вымышлены. Политика создана для тестирования локальной RAG-системы и не является юридической консультацией.

1. Назначение и область действия

Политика устанавливает обязательные правила защиты информации ООО «НордСофт». Она распространяется на штатных сотрудников, подрядчиков и стажёров, имеющих доступ к корпоративным системам или данным.

Каждый сотрудник отвечает за соблюдение правил в офисе, дома и в командировке. Незнание политики не освобождает от обязанности немедленно сообщать о подозрительном событии.

2. Классификация информации

Компания использует четыре уровня классификации:

1. **Публично** — информация, официально разрешённая к публикации без ограничений.
2. **Для внутреннего использования** — рабочая информация, доступная сотрудникам компании, но не предназначенная для публичного распространения.
3. **Конфиденциально** — договоры, непубличные финансовые показатели, исходный код закрытых продуктов и персональные данные сотрудников.
4. **Строго конфиденциально** — ключи шифрования, резервные коды многофакторной аутентификации, материалы расследований и выгрузки клиентских данных.

Владелец документа назначает уровень классификации при создании и пересматривает его при изменении содержания.

Конфиденциальные документы хранятся только в VaultBox или в другой одобренной корпоративной системе. Передача через личную почту, публичные файлообменники и личные облачные диски запрещена.

3. Пароли и многофакторная аутентификация

Пароль корпоративной учётной записи должен содержать не менее **14 символов**. Разрешены длинные парольные фразы. Запрещено использовать имя сотрудника, название компании, простые последовательности и пароль от личного сервиса.

Все корпоративные пароли подлежат плановой смене каждые **120 календарных дней**. Система не допускает повторное использование последних десяти паролей. После подозрения на

компрометацию пароль меняется немедленно независимо от даты предыдущей смены.

Многофакторная аутентификация обязательна для VPN, корпоративной почты, CodeForge, VaultBox и административных панелей. Резервные коды нельзя хранить в незашифрованном файле или рядом с рабочим устройством.

Передавать пароль, одноразовый код или резервный код другому человеку запрещено. Сотрудники ИТ-службы и службы информационной безопасности не запрашивают такие сведения по телефону, электронной почте или в корпоративном мессенджере.

4. Рабочие устройства и удалённый доступ

Доступ к корпоративным данным выполняется только с устройства, выданного компанией. Диск должен быть зашифрован, а автоматическая блокировка экрана должна включаться не позднее чем через пять минут бездействия.

Обновления безопасности устанавливаются в срок до **72 часов** после получения уведомления ИТ-службы. Отключение антивирусной защиты, агента мониторинга или шифрования диска запрещено.

Удалённое подключение к внутренним системам осуществляется через корпоративный VPN с многофакторной аутентификацией. Использование публичной сети Wi-Fi без активного VPN для работы с корпоративными данными запрещено.

При передаче рабочего устройства другому сотруднику или в ремонт необходимо оформить обращение в ServiceDesk. Самостоятельная передача устройства третьим лицам не допускается.

5. Использование внешних ИИ-сервисов

Запрещено отправлять данные уровней «Конфиденциально» и «Строго конфиденциально» во внешние генеративные ИИ-сервисы, включая публичные чат-боты и программные API. Ограничение действует даже при использовании личной платной подписки сотрудника.

Для работы с внутренними документами разрешена только корпоративная локальная RAG-система, развёрнутая в контролируемом контуре. Локальная система не должна передавать пользовательские запросы, фрагменты документов или результаты поиска внешним поставщикам моделей.

Публикация автоматически созданного ответа за пределами компании требует проверки владельцем информации. Ответ локального ассистента считается справочным и не заменяет утверждённый корпоративный документ.

6. Инциденты информационной безопасности

О потере устройства, подозрительном письме, ошибочной отправке документа, необычном входе или возможной утечке необходимо сообщить в течение **15 минут** с момента обнаружения.

Экстренные каналы:

- электронная почта: security@nordsoft.example;
- внутренний номер: **911**.

Обычная заявка в ServiceDesk не заменяет экстренное уведомление. Сотрудник не должен самостоятельно удалять журналы, переписку или файлы, связанные с событием.

После сообщения сотрудник следует инструкциям дежурного специалиста: отключает устройство от сети, завершает активные сессии или сохраняет состояние без перезагрузки — в зависимости от полученной команды.

Если сотрудник случайно ввёл корпоративный пароль на подозрительной странице, он должен немедленно прекратить работу с этой страницей, связаться со службой информационной безопасности и сменить пароль с доверенного устройства.

7. Ответственность и пересмотр

Подтверждённые нарушения рассматриваются комиссией с учётом умысла, последствий и скорости уведомления. Добросовестное оперативное сообщение об ошибке рассматривается как смягчающее обстоятельство.

Политика пересматривается не реже одного раза в год. Вопросы направляются на security@nordsoft.example.

При расхождении этой политики с более новым обязательным уведомлением службы информационной безопасности применяется более новое уведомление.

Ключевое правило: при подозрении на инцидент сначала уведомите службу безопасности, затем выполняйте полученные инструкции.